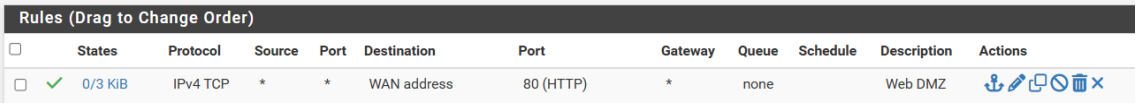
Simulació d'Atacs i Resposta

Una vegada configurat Suricata, definides les polítiques de seguretat i integrada la generació de logs amb Zabbix, el següent que farem serà validar el funcionament del sistema simulant un atac. Aquesta fase ens permet comprovar si les regles activades detecten correctament activitats sospitoses i si la resposta del sistema ens quadra amb lo que em definit per a cada interfície en la que esta actuant Suricata.

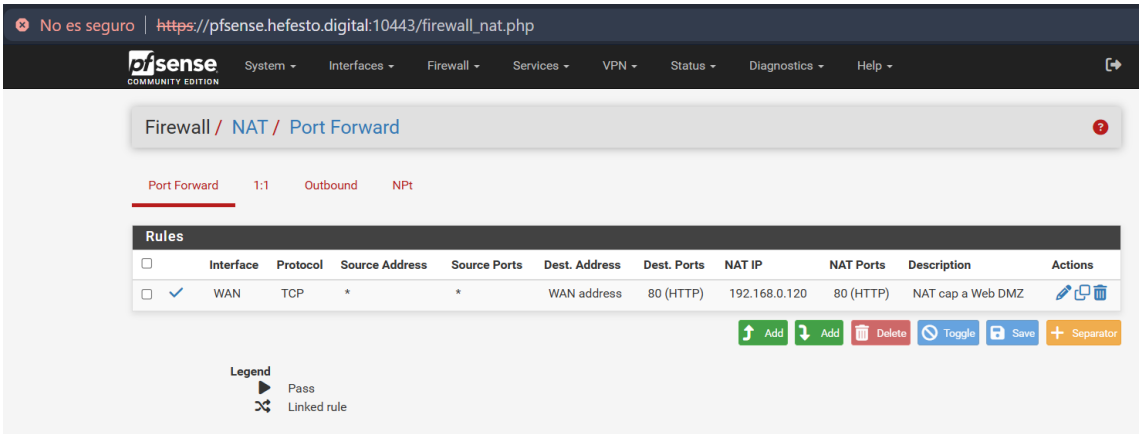
Simulació d'atacs específics per a comprovar l'eficàcia del sistema

Provarem a realitzar diferents patrons de tràfic per veure si Suricata ho detecta i en el cas de la DMZ i la WAN ho bloqueja:

Per obrir la web DMZ a internet s'ha fet una redirecció al pfSense del port 80 cap a la IP de la DMZ, a la WAN del Firewall em obert aquest port anteriorment per tal de tenir accés:



Per fer la redirecció em d'anar a "Firewall/NAT/Port Forward":



Simulació – Escaneig amb NMAP:

Per realitzar la primera simulació el company ha tirat des de la xarxa del Sapalomera un scan del nmap cap a la nostra infraestructura allotjada a casa, podem confirmar que ha funcionat perfectament i que fins que no em alliberat el bloqueig no es podia fer res des de el Sapalomera cap a casa.

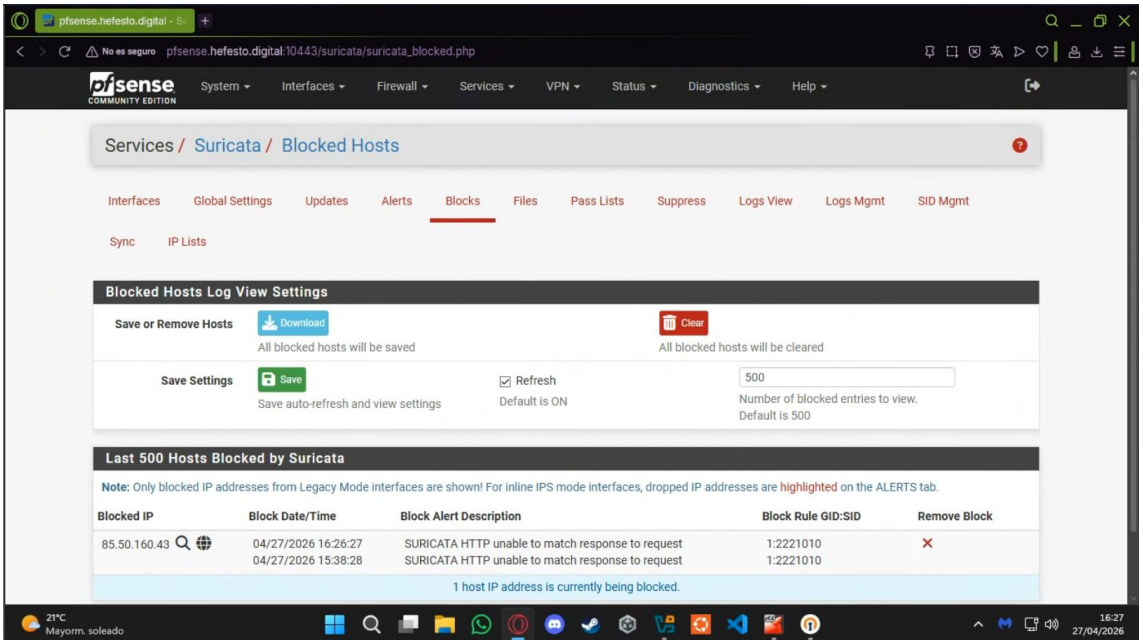
El primer pas ha estat tirar el scan:

```
gamer@PortalAxel:~$ sudo nmap -Pn -sS -sV -p 80 web.hefesto.digital
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-27 15:38 CEST
Nmap scan report for web.hefesto.digital (77.229.87.155)
Host is up (0.041s latency).
rDNS record for 77.229.87.155: static-155-87-229-77.ipcom.comunitel.net

PORT   STATE SERVICE VERSION
80/tcp open  http
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-
bin/submit.cgi?new-service :
SF-Port80-TCP:V=7.94SVN%I=7%D=4/27%Time=69EF66D5%P=x86_64-pc-linux-gnu%r(G
SF:etRequest,E9,"HTTP/1\.1\x20503\x20Service\x20Unavailable\r\ncontent-len
SF:gth:\x20107\r\ncache-control:\x20no-cache\r\ncontent-type:\x20text/html
SF:\r\nconnection:\x20close\r\n\r\n<html><body><h1>503\x20Service\x20Unava
SF:ilable</h1>\nNo\x20server\x20is\x20available\x20to\x20handle\x20this\x2
SF:0request\.\n</body></html>\n")%r(HTTPOptions,E9,"HTTP/1\.1\x20503\x20Se
SF:rvice\x20Unavailable\r\ncontent-length:\x20107\r\ncache-control:\x20no-
SF:cache\r\ncontent-type:\x20text/html\r\nconnection:\x20close\r\n\r\n<htm
SF:l><body><h1>503\x20Service\x20Unavailable</h1>\nNo\x20server\x20is\x20a
SF:vailable\x20to\x20handle\x20this\x20request\.\n</body></html>\n")%r(RTS
SF:PRequest,CF,"HTTP/1\.1\x20400\x20Bad\x20request\r\nContent-length:\x209
SF:0\r\nCache-Control:\x20no-cache\r\nConnection:\x20close\r\nContent-Type
SF::\x20text/html\r\n\r\n<html><body><h1>400\x20Bad\x20request</h1>\nYour\
SF:x20browser\x20sent\x20an\x20invalid\x20request\.\n</body></html>\n")%r(
SF:X11Probe,CF,"HTTP/1\.1\x20400\x20Bad\x20request\r\nContent-length:\x209
SF:0\r\nCache-Control:\x20no-cache\r\nConnection:\x20close\r\nContent-Type
SF::\x20text/html\r\n\r\n<html><body><h1>400\x20Bad\x20request</h1>\nYour\
SF:x20browser\x20sent\x20an\x20invalid\x20request\.\n</body></html>\n")%r(
SF:FourOhFourRequest,E9,"HTTP/1\.1\x20503\x20Service\x20Unavailable\r\ncon
SF:tent-length:\x20107\r\ncache-control:\x20no-cache\r\ncontent-type:\x20t
SF:ext/html\r\nconnection:\x20close\r\n\r\n<html><body><h1>503\x20Service\
SF:x20Unavailable</h1>\nNo\x20server\x20is\x20available\x20to\x20handle\x2
SF:0this\x20request\.\n</body></html>\n");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.11 seconds
```

Després em confirmat al pfSense que el sistema esta bloquejant la IP publica des de la que surt l'escaneig:



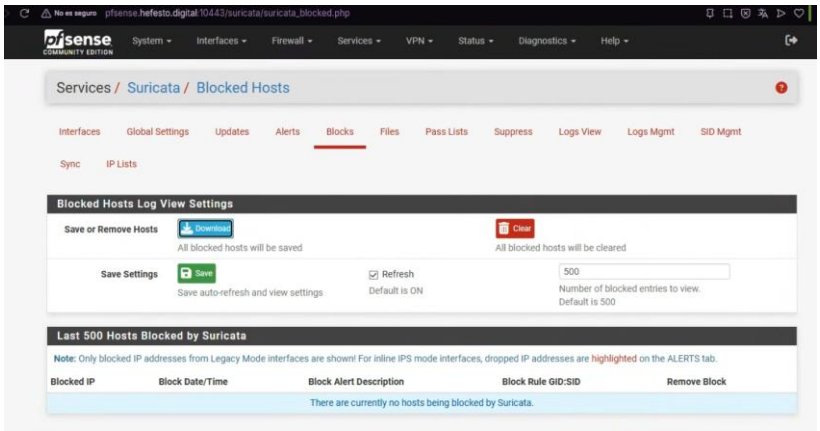
Un cop bloquejada el escaneig donarà el següent error:

```
gamer@PortalAxel:~$ sudo nmap -Pn -sS -sV -p 80 web.hefesto.digital
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-27 16:27 CEST
Nmap scan report for web.hefesto.digital (77.229.87.155)
Host is up.
rDNS record for 77.229.87.155: static-155-87-229-77.ipcom.comunitel.net

PORT   STATE    SERVICE VERSION
80/tcp filtered http

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.32 seconds
gamer@PortalAxel:~$
```

Ara ja alliberem la IP del Sapa per tal que el company recuperi l'accés des de fora i pugui tornar a connectar tant a la WEB com a la VPN:



Amb això queda confirmat el funcionament del IPS per la xarxa WAN, es correcte també la passlist ja que no ens talla cap connexió un cop ja estem connectats per la VPN.

Desenvolupament d'un pla de resposta a incidents

Davant la detecció d'una amenaça crítica, s'ha definit el següent protocol:

1. **Identificació:** Zabbix rep l'alerta de Suricata via Syslog i activa un disparador (Trigger) visual.

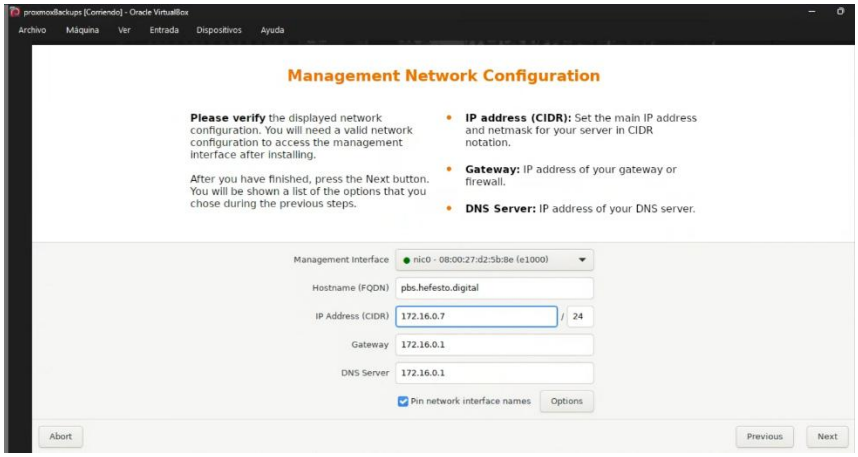
2. **Contenció:** Si l'atac persisteix, el mode IPS de pfSense bloquejarà la IP origen.

3. **Erradicació:** Revisió dels logs del Servidor Web per assegurar que cap petició maliciosa ha estat processada.

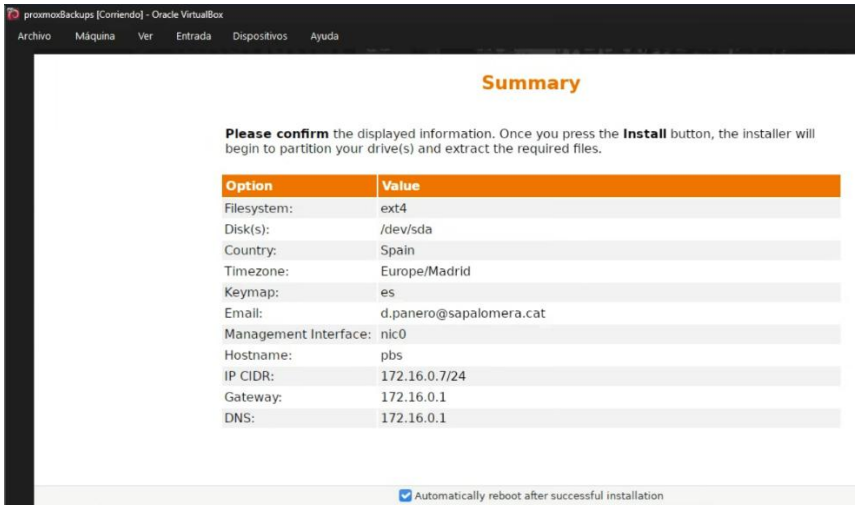
4. **Recuperació:** Em muntat un servidor “proxmox backup server” per tal que emmagatzemi al acabar el dia l’estat de les maquines en dispositius extraibles com ho serien per exemple unes cintes o un disc secundari USB que de manera mensual s’extrauran i etiquetaran per després canviar per un altre i asi de manera successiva.

   Aquestes copies s’aniran guardant en una altra ubicació física de manera que aconseguim protecció addicional en cas de problema físic a l’empresa com ho seria un incendi.

Per fer-ho primer de tot he instal·lat un proxmox addicional als que ja teníem (instal·lació dels nodes explicada al projecte “Proxmox”, he afegit dues targetes de xarxa una connectada a LAN i una altra a la xarxa amb la que proxmox es comunica amb el NAS (172.17...), aprofitem aquesta xarxa ja que la vam crear expressament per no saturar la LAN principal, la LAN (172.16...) la deixarem per administració:



Resultat final de configuració, un cop revisat, procedim amb la instal·lació



Ara li creo un DNS a pfSense per accedir còmodament a la administració:

Host Overrides

Host	Parent domain of host	IP to return for host	Description	Actions
bot	hefesto.digital	172.16.0.3	Hefesto AI	
pbs	hefesto.digital	172.16.0.7	Backup Server Proxmox	
pfsense	hefesto.digital	172.16.0.1	pfsense	
proxmox	hefesto.digital	172.16.0.4	Cluster Proxmox (IP flotante)	
truenas	hefesto.digital	172.16.0.9	TrueNAS	
web	hefesto.digital	10.0.0.10	Web DMZ	
zabbix	hefesto.digital	172.16.0.5	Zabbix Server	

Enter any individual hosts for which the resolver's standard DNS lookup process should be overridden and a specific IPv4 or IPv6 address should automatically be returned by the

Accedeixo a aquest nou server i li dono IP a la segona targeta de xarxa que es per on comunicarà amb el clúster:

No es seguro | ~~https~~://pbs.hefesto.digital:8007/#pbsXtermJsConsole

Backup Server 4.1.0

```
 GNU nano 8.4                                    /etc/network/interfaces
auto lo
iface lo inet loopback

auto nic0
iface nic0 inet static
        address 172.16.0.7/24
        gateway 172.16.0.1

auto nic1
iface nic1 inet static
        address 172.17.0.6/24

source /etc/network/interfaces.d/*
```

```
root@pbs:~# systemctl restart networking.service
root@pbs:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: nic0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:d2:5b:8e brd ff:ff:ff:ff:ff:ff
    altname enx080027d25b8e
    inet 172.16.0.7/24 scope global nic0
       valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fed2:5b8e/64 scope link tentative proto kernel_ll
       valid_lft forever preferred_lft forever
3: nic1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:97:e2:16 brd ff:ff:ff:ff:ff:ff
    altname enx08002797e216
    inet 172.17.0.6/24 scope global nic1
       valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe97:e216/64 scope link proto kernel_ll
       valid_lft forever preferred_lft forever
```

Creo un datastore al pbs, de moment com que no tenim cap USB connectat el provarem en el disc Local del propi backup-server:

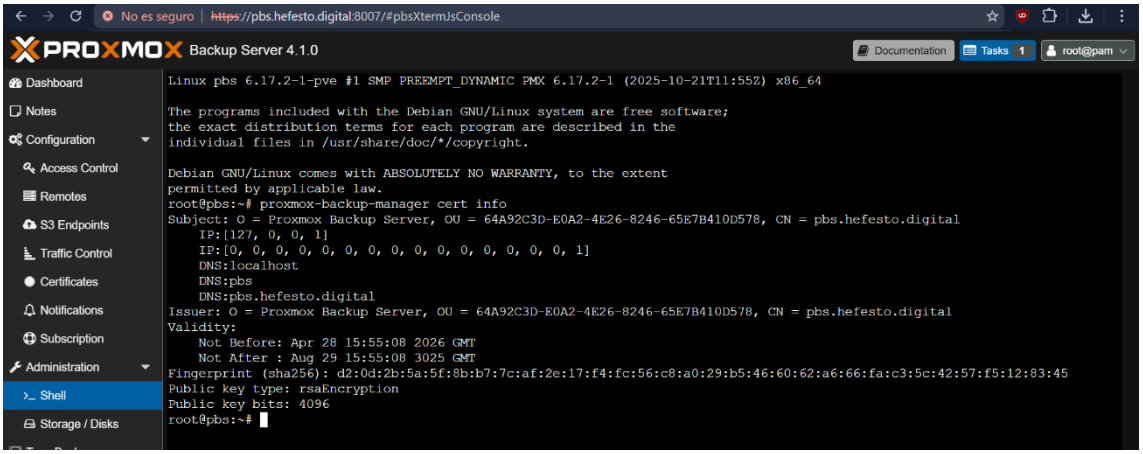
Add: Datastore

General | Prune Options

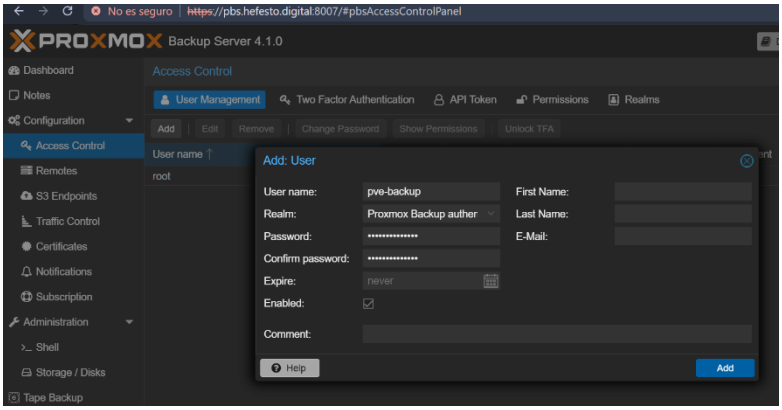
Name:	hefesto-backups	GC Schedule:	daily
Datastore Type:	Local	Prune Schedule:	daily
Backing Path:	/mnt/datastore/hefesto-back	Device:	Device path
S3 Endpoint ID:		Bucket:	
Comment:			

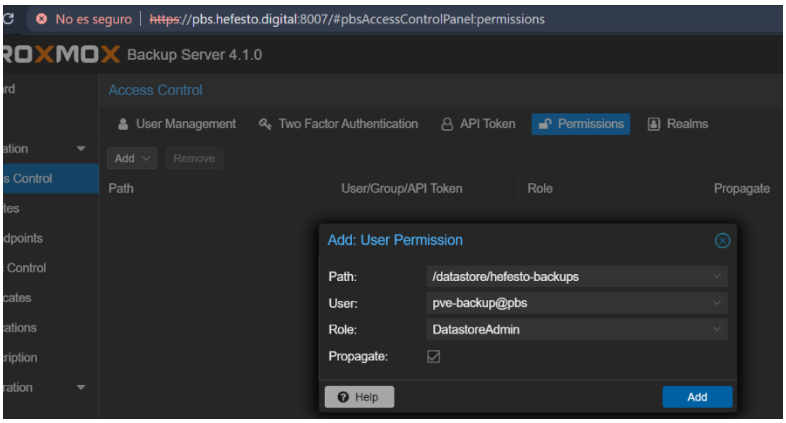
Help | Advanced ☐ | Add

Amb la comanda “proxmox-backup-manager cert info” obtinc el “fingerprint sha256” que ens farà falta més endavant:

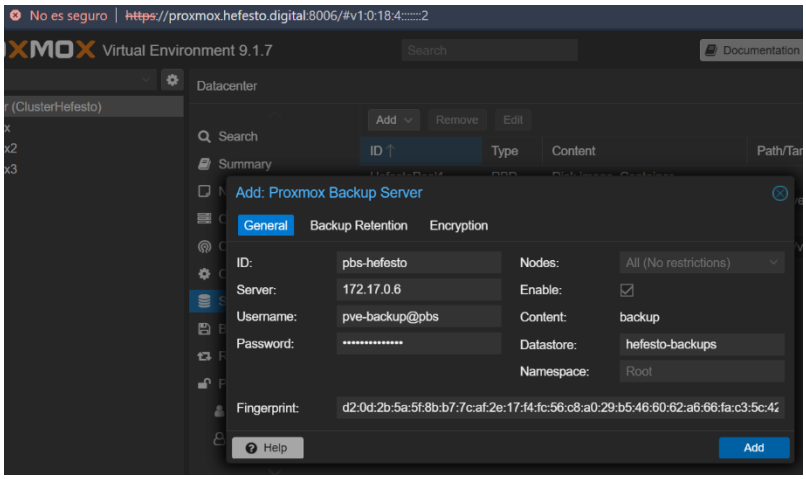


Creo un usuari i li dono permisos per administrar aquests backups:





Ara ja podem anar al clúster de proxmox i afegir aquest servidor:



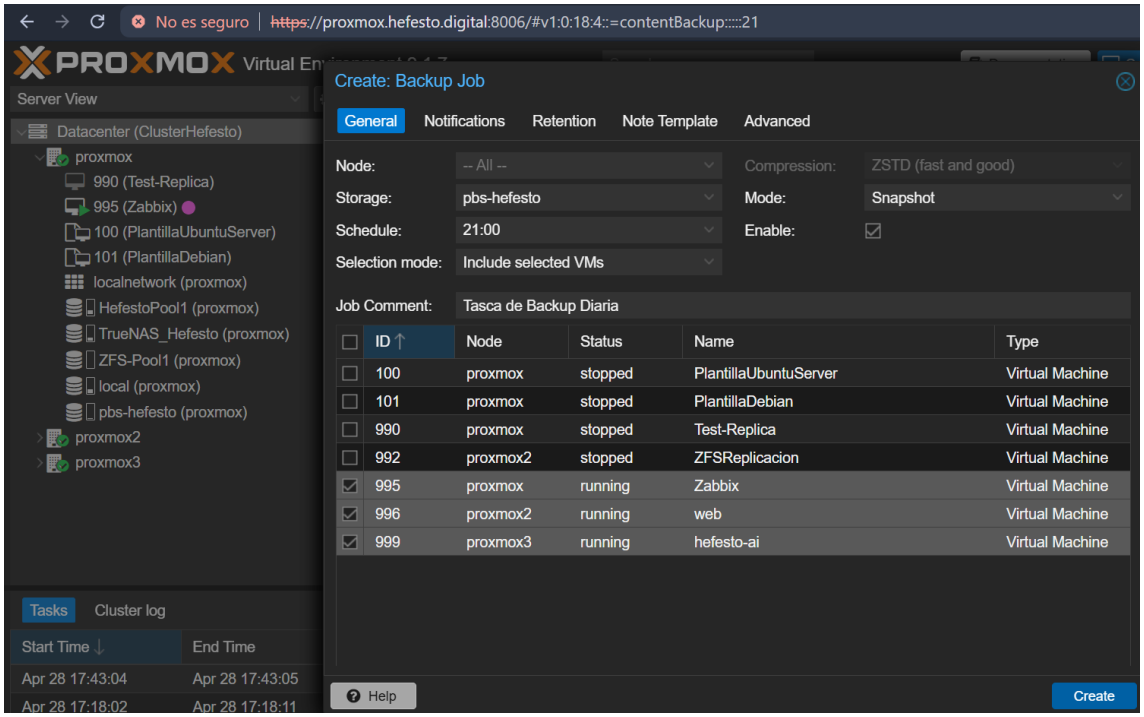
Amb això ja queda afegit el servidor de backups al nostre clúster de proxmox, en el següent punt mirarem de provar i analitzar el sistema i intentarem automatitzar-lo.

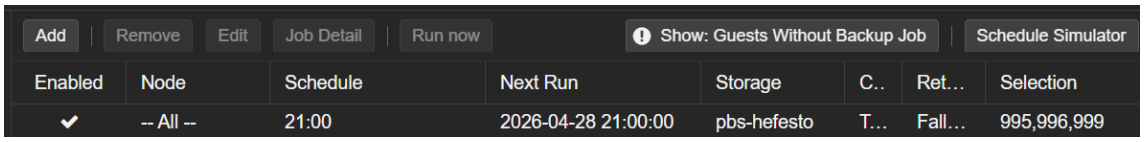
Anàlisi i millora de la resposta a situacions crítiques

La resposta comença en el moment que IPS bloqueja la connexió (prova ja realitzada i funciona perfectament) el que ens quedaria saber es si després podríem reprendre el sistema en un punt anterior al atac.

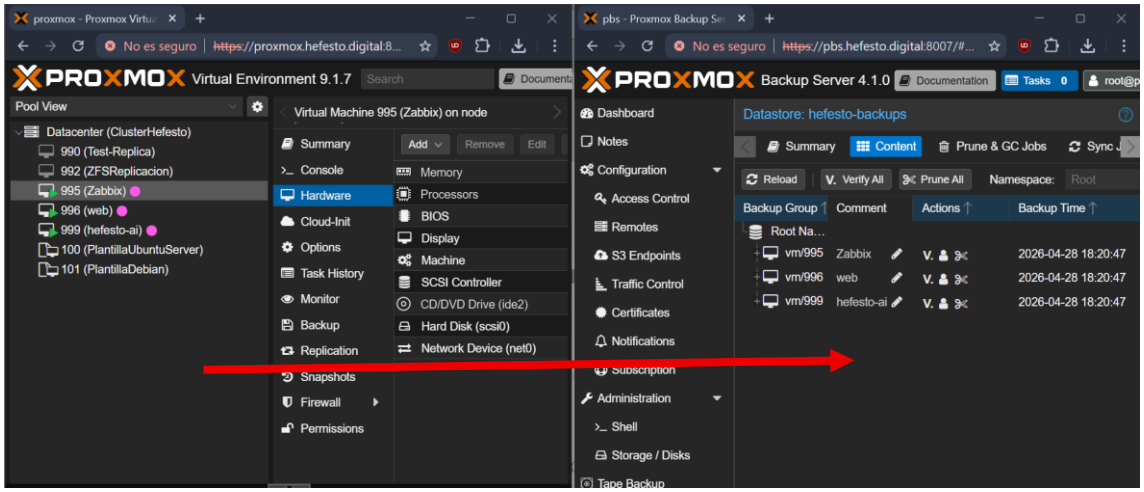
El primer pas ha estat crear una tasca de backup diari, per no saturar el sistema ja que es una simulació només passarem les VMs ja que les maquines que principalment estan en marxa i podrien ser atacades son aquestes.

Indico el mode que serà "snapshot" per guardar la instantània de la maquina en aquell moment i on i quan volem guardar, en el nostre cas em decidit a les 21:00 de cada dia i òbviament en el storage creat al server pbs:

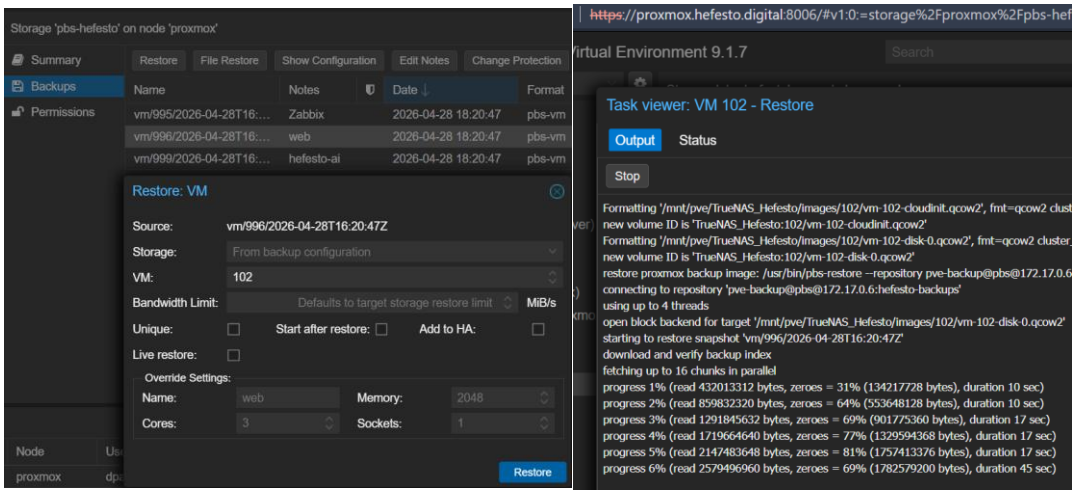




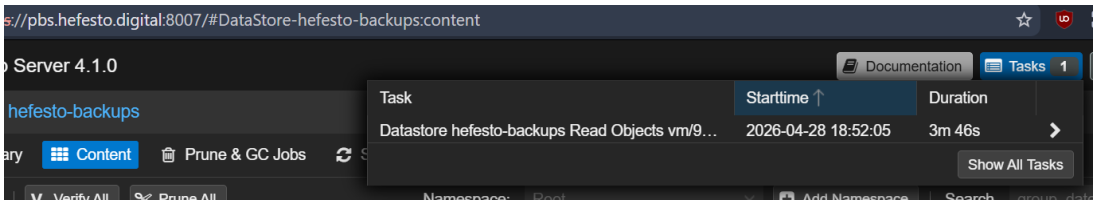
He forçat el backup per que el realitzi ara mateix i podem veure com el server pbs rep els backups correctament:



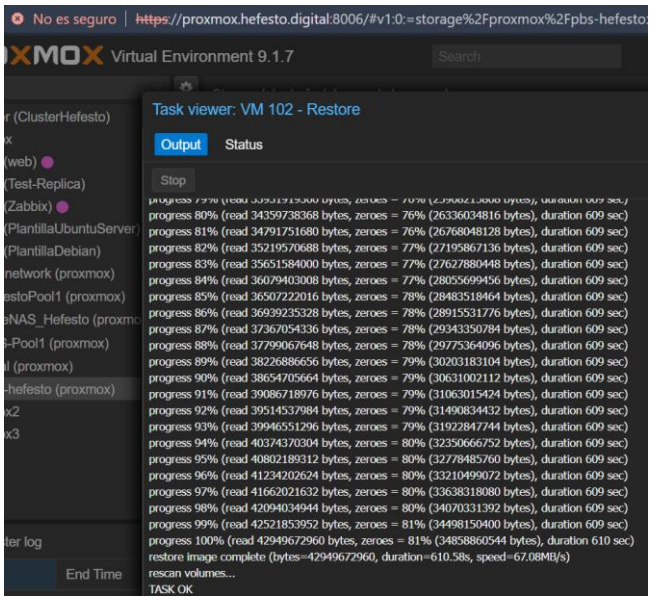
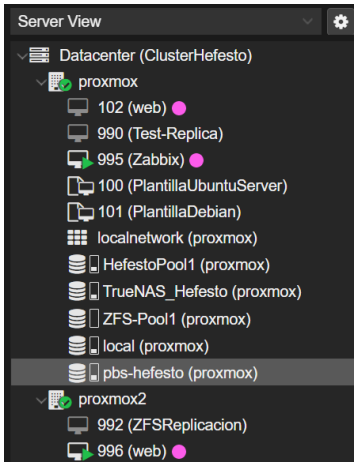
Ara mirarem de restaurar aquest backup:



Podem veure que al servidor de backups ens mostra una notificació amb la tasca en curs:



Resultat de la maquina virtual ja restaurada:



Com es pot veure a continuació ens ha creat una nova maquina restaurada que porta exactament el contingut de la original de la qual s'ha extret el backup, com era el primer cop em decidit fer que el restore generi una copia a un altre node de proxmox però es podria fer que la planxi a sobre perfectament: